

PrintNightmare — LetsDefend Incident Investigation

1. Introduction

This report documents the investigation of a Windows system compromised through the **PrintNightmare vulnerability (CVE-2021-34527)**.

The objective of the investigation was to identify the attacker infrastructure, determine how the vulnerability was exploited, identify the malicious DLL and payload, investigate authentication and persistence activity, and identify artifacts left on the compromised system.

The investigation was performed using network traffic and endpoint evidence provided with the LetsDefend challenge.

2. Scenario

The investigated Windows environment was compromised through the **PrintNightmare vulnerability**. The attack involved suspicious SMB activity, a malicious DLL hosted on an attacker-controlled SMB share, domain authentication, creation of a new privileged user account, and establishment of a reverse HTTPS connection.

The investigation therefore focused on reconstructing the attack chain by correlating:

- Network traffic
 - SMB activity
 - Authentication records
 - Windows Event Logs
 - User accounts
 - Network connections
 - Running processes
 - Filesystem artifacts
-

3. Tools and Evidence Used

3.1 Zui

Zui was used to analyze the provided PCAP file and investigate network activity.

Primary uses:

- IDS alerts
- SMB traffic
- Network connections
- NTLM authentication
- SSL/TLS information
- SMB file transfers
- Attacker infrastructure

Evidence analyzed:

`challenge-v1.pcapng`

3.2 Redline

Mandiant Redline was used for host-based investigation.

Primary uses:

- User accounts
- User privileges and group membership
- Windows Event Logs
- Network connections
- Processes
- Filesystem artifacts

Evidence analyzed:

`AnalysisSession1.mans`

3.3 Wireshark

Wireshark can be used to independently inspect the supplied PCAP and validate network-level findings, particularly SMB file transfers and connection details.

4. Investigation and Findings

4.1 Identification of the Vulnerability

Question

Looking through the alerts in Zui, what is the vulnerability name and its corresponding CVE?

Finding

PrintNightmare — CVE-2021-34527

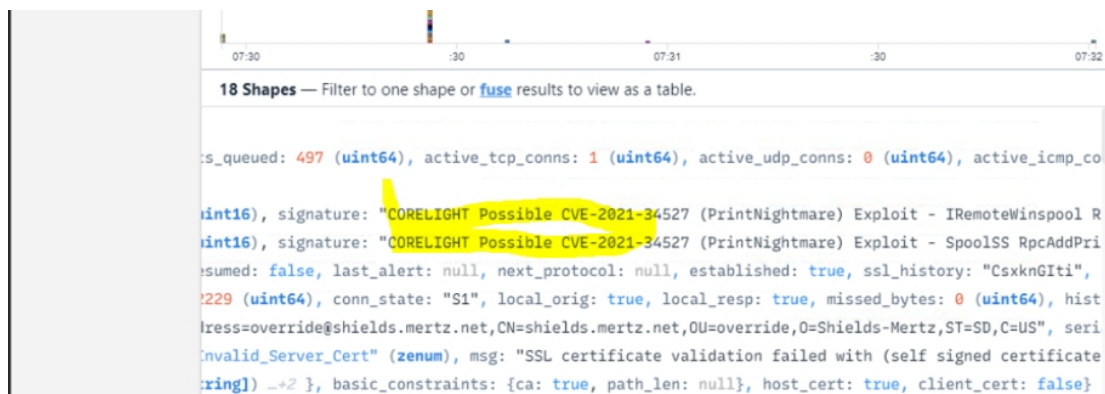
Analysis

The Zui alert contained a Corelight detection identifying a possible:

CVE-2021-34527 (PrintNightmare) Exploit

The alert also referenced Print Spooler-related exploitation activity. This established the initial vulnerability associated with the incident.

Evidence



[Zui alert showing CVE-2021-34527 / PrintNightmare]

4.2 Identification of the Attacker IP

Question

What is the attacker's IP?

Finding

10.10.10.2

Analysis

Network records showed communication between 10.10.10.2 and 10.10.10.4.

Further SMB, DCE/RPC and authentication activity associated 10.10.10.2 with the suspicious attack sequence. The host also exposed services used during the attack, including SMB and HTTPS.

Therefore, 10.10.10.2 was identified as the attacker-controlled host.

Evidence

Relevant network records showed connections involving:

10.10.10.2
10.10.10.4

```
18 Shapes — Filter to one shape or fuse results to view as a table.

92, ts_delta: 1m3.795788s, peer: "zeek", gaps: 0 (uint64), acks: 92 (uint64), percent
r: "zeek", mem: 101 (uint64), pkts_proc: 889 (uint64), bytes_recv: 724021 (uint64),
12, ts_delta: 1m374.716ms, peer: "zeek", gaps: 0 (uint64), acks: 466 (uint64), perce
1532, src_ip: 10.10.10.4, src_port: 49944 (port=(uint16)), dest_ip: 10.10.10.2, dest
1532, src_ip: 10.10.10.4, src_port: 49944 (port=(uint16)), dest_ip: 10.10.10.2, dest
"C2BEhjn6Gcgmeetn6", id: {orig_h: 10.10.10.4, orig_p: 49946 (port=(uint16)) ...+2 }, v
"C2BEhjn6Gcgmeetn6", id: {orig_h: 10.10.10.4, orig_p: 49946 (port=(uint16)) ...+2 },
Z, host: 10.10.10.2, port_num: 443 (port=(uint16)), subject: "emailAddress=override@
d: "Cb0Jff2rEuwrlZRRxi", id: {orig_h: 10.10.10.4, orig_p: 49945 (port=(uint16)) ...+2 }
```

[Zui connection/SMB evidence]

4.3 Identification of the Attacker SMB Share

Question

What is the attacker's share path?

Finding

```
\\10.10.10.2\share
```

Analysis

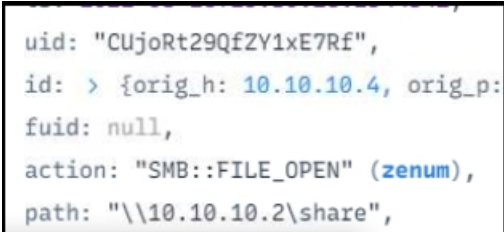
An SMB mapping record showed the following path:

```
action: SMB::FILE_OPEN  
path: \\10.10.10.2\share
```

The connection involved the attacker-controlled host 10.10.10.2.

This indicates that the attacker exposed a Windows SMB share containing resources used during the attack.

Evidence



```
uid: "CUjoRt29QfZY1xE7Rf",  
id: > {orig_h: 10.10.10.4, orig_p:  
fuid: null,  
action: "SMB::FILE_OPEN" (zenum),  
path: "\\10.10.10.2\share",
```

[SMB FILE_OPEN showing \\10.10.10.2\share]

4.4 Identification of the Malicious DLL

Question

What is the name of the malicious DLL file hosted by the attacker?

Finding

notsostealthy.dll

Analysis

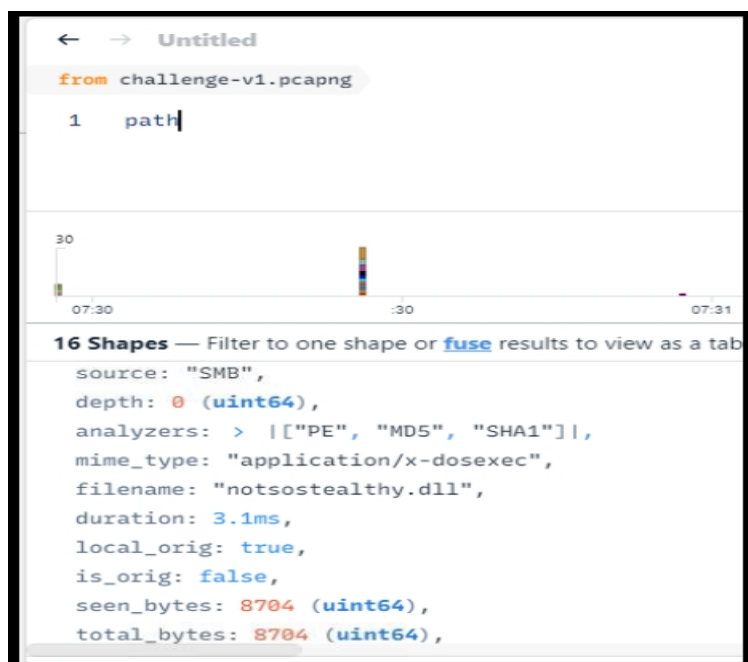
The SMB file-transfer records showed a DLL being accessed through the attacker-controlled SMB share.

The relevant record identified:

```
source: SMB
filename: notsostealthy.dll
mime_type: application/x-dosexec
```

The file was therefore treated as a malicious executable artifact involved in the exploitation chain.

Evidence



[Zui SMB file record showing notsostealthy.dll]

4.5 MD5 Hash of the Malicious DLL

Question

What is the MD5 hash of the DLL file?

Finding

MD5: [INSERT THE MD5 YOU FOUND]

Analysis

The DLL was extracted/identified from the SMB traffic and its file hash was calculated to uniquely identify the artifact.

The MD5 value can be used as an IOC for detecting the same file in other systems or threat-intelligence platforms.

Evidence

```
missing_bytes: 0 (uint64),
overflow_bytes: 0 (uint64),
timedout: false,
parent_fuid: null,
md5: "8ac469b77518820bbf0603a9ad56691d",
sha1: "a3f4040b9f0e7245d08dc4b248a9dae4f0542e2e",
sha256: null,
extracted: null,
```

[DLL hash / VirusTotal / extracted file evidence]

4.6 Self-Signed SSL Certificate

Question

What is the email address used for the self-signed SSL certificate in the traffic?

Finding

override@shields.mertz.net

Analysis

The Zui `known_certs` record showed an SSL certificate associated with:

```
host: 10.10.10.2  
port: 443
```

The certificate contained:

```
emailAddress=override@shields.mertz.net
```

The `subject` and `issuer_subject` were identical, indicating that the certificate was self-signed.

This certificate is significant because the attacker later used HTTPS communication on port 443.

Evidence

```
ts: 2021-08-16T19:30:26.355362Z,  
host: 10.10.10.2,  
port_num: 443 (port=(uint16)),  
subject: "emailAddress=override@shields.mertz.net,CN=shields.mertz.net,OU=overri  
issuer_subject: "emailAddress=override@shields.mertz.net,CN=shields.mertz.net,OU  
serial: "18FB74774B112DB6"
```

[`known_certs` record]

4.7 Domain User Used During Exploitation

Question

What is the domain user used by the attacker to exploit the vulnerability?

Finding

```
BELLYBEAR\Jesse.Harmon
```

Analysis

An NTLM authentication record associated with the suspicious network activity showed:

```
username: Jesse.Harmon  
domainname: BELLYBEAR
```

```
orig_h: 10.10.10.2
success: true
```

This linked the domain account `Jesse.Harmon` with the attacker-originated activity.

Evidence

	username	hostname	domainname	server_nb_computer_name	server
...+2 }	Jesse.Harmon	null	BELLYBEAR	WIN-FL04EU2VMSM	WIN-F

[Zui NTLM record showing username, domain and origin IP]

4.8 Exploit Server Hostname

Question

What is the exploit server's hostname?

Finding

```
WIN-FLO4EU2VMSM
```

Analysis

The NTLM record associated with the exploitation activity contained:

```
server_nb_computer_name:
WIN-FLO4EU2VMSM
```

The corresponding DNS name was:

```
WIN-FLO4EU2VMSM.bellybear.local
```

The short hostname is therefore:

```
WIN-FLO4EU2VMSM
```

Evidence

hostname	domainname	server_nb_computer_name	server_dns_computer_name	server_dns_domain_name
FLO4EU2VMSM	null	EvKzrMVPq	EvKzrMVPq	null
BELLYBEAR	WIN-FLO4EU2VMSM	WIN-FLO4EU2VMSM.bellybear.local	bellybear.local	bellybear.local

[Zui NTLM record showing hostname]

4.9 Persistence Account

Question

What is the username created by the attacker for persistence?

Finding

hacker

Analysis

Redline's **Users** section showed a non-standard account named `hacker`.

The account had membership in:

Domain Users
Administrators
Remote Desktop Users
Users

The combination of a non-standard username with membership in the **Administrators** and **Remote Desktop Users** groups made the account significant for persistence investigation.

The account was enabled and therefore capable of being used for continued access.

Evidence

Enter string to find here...					
In All Fields					
Clear Column Filters					
Prev Next					
Username	SID	SID Type	Full Name	Description	
Administrator	S-1-5-2...	SidTypeUser	BELLYBEAR\Administrator	Built-in account for...	
Guest	S-1-5-2...	SidTypeUser	BELLYBEAR\Guest	Built-in account for...	
krbtgt	S-1-5-2...	SidTypeUser	BELLYBEAR\krbtgt	Key Distribution Cer...	
Jesse.Harmon	S-1-5-2...	SidTypeUser	BELLYBEAR\Jesse.Harmon		
hacker	S-1-5-2...	SidTypeUser	BELLYBEAR\hacker		
WIN-FLO4EU2VMSMS	S-1-5-2...	SidTypeUser	BELLYBEAR\WIN-FLO4EU...		
DWM-2			Window Manager\DWM-2		
UMFD-0			Font Driver Host\UMFD-0		
UMFD-2			Font Driver Host\UMFD-2		
LOCAL SERVICE	S-1-5-19	SidTypeWellKnownGroup	NT AUTHORITY\LOCAL S...		

[Redline Users list]

Username:	hacker
Security ID:	S-1-5-21-1775724954-3982130797-2058104931-1104
Security Type:	SidTypeUser
User Account Information	
Full Name:	BELLYBEAR\hacker
Description:	Empty String
Home Directory:	Empty String
Script Path:	Empty String
Last Login:	1970-01-01 00:00:00Z
Disabled:	False
Locked Out:	False
Password Required:	True
Password Age:	03:05:03
Groups:	Domain Users,Administrators,Remote Desktop Users,Users

[Redline hacker account details]

4.10 Windows Event ID for User Creation

Question

What is the event ID for user creation in Windows, and when was the user created?

Finding

Event ID: 4720
Time: 2021-08-16 19:31:46Z

Analysis

Redline showed a Windows Security event with:

Event ID: 4720

Message: A user account was created.

The event identified the newly created account as:

BELLYBEAR\hacker

The event timestamp was:

2021-08-16 19:31:46Z

Event ID 4720 therefore provides host-based evidence supporting the creation of the `hacker` account.

Evidence



[Redline Event ID 4720 showing `hacker` and timestamp]

4.11 Shell Connection Process and Listening Port

Question

What process name is used to establish the shell connection between the attacker's machine and the Windows server, and what is the listening port on the attacker's machine?

Finding

Process: rundll32.exe
Listening Port: 443

Analysis

Redline identified a TCP connection with:

Local IP: 10.10.10.4
Local Port: 49946

Remote IP: 10.10.10.2
Remote Port: 443

The associated process was:

rundll32.exe
PID: 1256
Path: C:\Windows\System32\rundll32.exe

Because 10.10.10.2 was identified as the attacker host, the remote port 443 represents the listening port on the attacker side.

rundll32.exe is a legitimate Windows utility used to load DLLs. Its presence in this connection is significant because it can be abused to execute malicious DLL content.

Evidence

Port Information	
Protocol:	TCP
State:	ESTABLISHED
Created:	Not Available
Endpoints	
Local IP:	10.10.10.4
Local Port:	49946
Remote IP:	10.10.10.2
Remote Port:	443
Process Information	
PID:	1256
Process:	rundll32.exe
Path:	C:\Windows\System32\rundll32.exe

[Redline Port Information showing IPs, ports and rundll32.exe]

4.12 Post-Exploitation Payload

Question

The attacker used a famous post-exploitation framework to create the DLL file and establish the shell connection to the Windows server. What payload did the attacker use?

Finding

```
payload/windows/x64/meterpreter/reverse_https
```

Analysis

The malicious DLL was associated with **Meterpreter**, a post-exploitation payload associated with the Metasploit framework.

The observed HTTPS communication to port 443, combined with the Meterpreter evidence, is consistent with a Windows x64 Meterpreter reverse HTTPS payload.

The payload name identifies:

- windows — Windows target
- x64 — 64-bit architecture
- meterpreter — Meterpreter payload
- reverse_https — reverse connection over HTTPS

The reference analysis also identifies this exact payload as the one associated with the attack.

Evidence

[INSERT SCREENSHOT — DLL/VT evidence showing Meterpreter]

4.13 Text File Left for Administrator

Question

The attacker left a text file for the user Administrator. What is the filename?

Finding

This-Is-Really-A-Nightmare.txt

Analysis

Redline filesystem analysis identified the file under:

C:\Users\Administrator\Documents\

The complete path was:

C:\Users\Administrator\Documents\This-Is-Really-A-Nightmare.txt

The file metadata showed:

Size: 31 bytes
Created: 2021-08-16 19:58:15Z
Modified: 2021-08-16 19:58:15Z

This provides a final filesystem artifact associated with the post-exploitation activity.

Evidence

File Metadata					
Full Path:	C:\Users\Administrator\Documents\This-Is-Really-A-Nightmare.txt				
Size:	31 Bytes				
Attributes:	Archive				
INode:	Not Available				
File Hashes					
MD5:	a146e07296febb2f26aaf025bb92ff9e				
SHA1:	Not Available				
SHA256:	Not Available				
Timestamps					
Created:	2021-08-16 19:58:15Z				
Modified:	2021-08-16 19:58:15Z				
Accessed:	2021-08-16 19:58:15Z				
Changed:	2021-08-16 19:58:15Z				
Filename Created:	Not Available				
Filename Modified:	Not Available				
Filename Accessed:	Not Available				
Filename Changed:	Not Available				
User Information					
Username:	NT AUTHORITY\SYSTEM				
Security ID:	S-1-5-18				
Security Type:	SidTypeWellKnownGroup				
File Path Parts					
Device Path:	\Device\HarddiskVolume3				
Drive Letter:	C				
Details	Duplicates	Alternate Data Streams	Strings	Imports	Exports

[Redline File Metadata]

5. Attack Chain Summary

The investigation established the following attack sequence:

```
PrintNightmare
CVE-2021-34527
↓
Attacker: 10.10.10.2
↓
SMB Share
\\10.10.10.2\share
↓
Malicious DLL
notsostealthy.dll
↓
Domain Authentication
BELLYBEAR\Jesse.Harmon
↓
Windows Host
WIN-FLO4EU2VMSM
↓
Persistence Account
BELLYBEAR\hacker
↓
Windows Event ID 4720
↓
rundll32.exe
↓
HTTPS Connection
10.10.10.2:443
↓
Meterpreter
reverse_https
↓
Administrator Artifact
This-Is-Really-A-Nightmare.txt
```

This correlation between network, authentication, process, account, and filesystem evidence provides a coherent view of the intrusion.

6. Indicators of Compromise

IOC Type	Indicator
Vulnerability	CVE-2021-34527
Vulnerability Name	PrintNightmare
Attacker IP	10.10.10.2
Victim IP	10.10.10.4
SMB Share	\\10.10.10.2\share
Malicious DLL	notsostealthy.dll
DLL MD5	[INSERT VERIFIED MD5]
SSL Certificate Email	override@shields.mertz.net
Domain	BELLYBEAR
Domain User	Jesse.Harmon
Hostname	WIN-FLO4EU2VMSM
Persistence User	hacker
User Creation Event	4720
User Creation Time	2021-08-16 19:31:46Z
Process	rundll32.exe
Attacker Listening Port	443/TCP
Payload	payload/windows/x64/meterpreter/reverse_https
Dropped Text File	This-Is-Really-A-Nightmare.txt
File Path	C:\Users\Administrator\Documents\This-Is-Really-A-Nightmare.txt

7. Answers Summary

#	Challenge Question	Answer
1	Vulnerability and CVE	PrintNightmare — CVE-2021-34527
2	Attacker's IP	10.10.10.2
3	Attacker's share path	\\10.10.10.2\share
4	Malicious DLL	notsostealthy.dll
5	MD5 hash	[INSERT VERIFIED MD5]
6	SSL certificate email	override@shields.mertz.net
7	Domain user	BELLYBEAR\Jesse.Harmon
8	Exploit server hostname	WIN-FLO4EU2VMSM
9	Persistence username	hacker
10	User creation Event ID / time	4720 — 2021-08-16 19:31:46Z
11	Shell process / attacker port	rundll32.exe / 443
12	Payload	payload/windows/x64/meterpreter/reverse_https
13	Administrator text file	This-Is-Really-A-Nightmare.txt

8. Conclusion

The investigation successfully reconstructed a PrintNightmare exploitation chain using both network and host-based evidence. Zui was used to identify the vulnerability, attacker infrastructure, SMB share, malicious DLL, authentication activity, certificate information, and network connections. Redline was then used to investigate endpoint artifacts, including the persistence account, Windows account-creation event, `rundll32.exe` network connection, and the text file left on the system.

The evidence demonstrated how correlating multiple sources can provide a clearer picture of an attack than relying on a single log or alert.

Thanks to LetsDefend for providing the challenge, investigation data, and lab environment.